Panorama des outils DevSecOps

Catégories, alternatives et placement dans un pipeline CI/CD

Octobre 2026

Sommaire

Sommaire 2
1. Pre-commit et détection de secrets 3
2. SAST (analyse du code source) 3
3. SCA (dépendances tierces) 4
4. Supply chain logicielle (SBOM, signature, provenance) 4
5. Images de conteneurs (CA) 5
6. IaC et policy as code 6
7. DAST (application en fonctionnement) 6
8. Sécurité runtime et gestion des secrets 7
9. Observabilité, DORA et SIEM 7
10. Centralisation des résultats (ASPM) 8
11. Placement dans un pipeline CI/CD 9

1. Pre-commit et détection de secrets

Premier filet de sécurité, sur le poste du développeur. À doubler côté serveur : un hook local peut être contourné (--no-verify).

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Lefthook	Gestionnaire de hooks Git	—	MIT	Binaire Go rapide, config YAML simple, hooks en parallèle.
pre-commit (framework)	Gestionnaire de hooks	—	MIT	Standard historique (Python), énorme catalogue de hooks prêts à l'emploi.
Husky	Gestionnaire de hooks	—	MIT	Naturel dans les projets JS/Node (installé via npm).
Gitleaks	Secrets	Scan de l'historique Git	MIT	Léger, rapide, règles regex personnalisables.
TruffleHog	Secrets	Scan S3, Docker, Slack, etc.	AGPL	**Vérifie que le secret est actif** (appel API) : beaucoup moins de faux positifs.
GitGuardian / GitHub Secret Scanning	Secrets (SaaS)	Push protection côté serveur	Propriétaire	Bloque au push même si le hook local a été contourné.

2. SAST (analyse du code source)

Recherche de failles dans la logique du code (injections, XSS, désérialisation…), sans l'exécuter.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
SonarQube	SAST + qualité de code	Secrets ; scan IaC basique (Terraform, K8s, Docker)	Community gratuite / payant	Quality gates et dette technique. La taint analysis (vraie sécurité) est surtout dans les éditions payantes.
CodeQL	SAST	—	Gratuit repos publics / GHAS	Analyse sémantique très fine, requêtes écrites en QL. Lent sur gros monorepos.
Snyk (Snyk Code)	SAST	SCA, Container, IaC (même plateforme)	SaaS freemium	Plateforme tout-en-un, très bon retour dans l'IDE. Coût vite élevé.
Semgrep	SAST	SCA (Supply Chain, payant), secrets	CE open source / payant	Règles faciles à écrire soi-même, très rapide en CI.
Bandit / gosec / Brakeman	SAST spécialisés	—	Open source	Par langage (Python / Go / Rails). Légers, à combiner avec un SAST généraliste.
Checkmarx / Veracode / Fortify	SAST entreprise	SCA, DAST, IaC selon offre	Propriétaire	Orientés conformité et gros portefeuilles applicatifs.

3. SCA (dépendances tierces)

Détection des vulnérabilités connues (CVE) et des licences dans les bibliothèques utilisées.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Dependabot	SCA + PR de mise à jour	—	Gratuit (GitHub)	Zéro config sur GitHub. Moins configurable que Renovate.
Renovate	Mises à jour de dépendances	Images Docker, Helm, Terraform, GitHub Actions	AGPL / Mend	Groupement, automerge, multi-forge (GitLab, Bitbucket…).
Trivy fs	SCA	Secrets, licences, IaC (Terraform, K8s, Helm, Dockerfile) ; **Ansible partiel** (support récent, toutes les fonctionnalités Ansible ne sont pas couvertes)	Apache 2.0	Un seul binaire pour tout. **Pas un SAST** : il ne lit pas la logique du code.
Snyk Open Source	SCA	Licences, suggestions de correctifs	SaaS freemium	Base de vulnérabilités enrichie, PR de correction automatiques.
OSV-Scanner	SCA	Licences	Apache 2.0	Base OSV (Google), simple, gratuit, faible bruit.
OWASP Dependency-Check	SCA	—	Apache 2.0	Historique dans l'écosystème Java ; plus lent et plus bruyant que Trivy/OSV.

4. Supply chain logicielle (SBOM, signature, provenance)

Garantir que ce qui tourne en production est bien ce que la CI a construit, à partir de composants connus. Répond aux exigences récentes (Cyber Resilience Act européen, NIS2, SLSA).

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Syft	Génération de SBOM	—	Apache 2.0	SBOM CycloneDX / SPDX depuis une image ou un dossier. Couplé à Grype.
cdxgen	Génération de SBOM	—	Apache 2.0	Projet OWASP CycloneDX, très large support de langages.
Trivy	Scanner	Génère aussi des SBOM (CycloneDX/SPDX)	Apache 2.0	Évite un outil de plus si Trivy est déjà en place.
Dependency-Track	Gestion continue des SBOM	Politiques de licences	Apache 2.0	Ingère les SBOM de tous les projets et **alerte quand une nouvelle CVE touche un composant déjà en prod**.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Cosign (Sigstore)	Signature d'images et artefacts	Attestations (SBOM, provenance)	Apache 2.0	Signature « keyless » via OIDC de la CI, transparence via Rekor.
Notation (Notary v2)	Signature d'images	—	Apache 2.0	Alternative à Cosign, poussée par Microsoft/Azure.
SLSA / in-toto	Provenance de build	—	Spécification ouverte	Atteste comment, où et à partir de quoi l'artefact a été construit.
GitHub Artifact Attestations / slsa-github-generator	Provenance SLSA	—	Gratuit (GitHub)	SLSA niveau 2-3 sans infrastructure à gérer.
OpenSSF Scorecard	Santé des dépendances open source	Audit de ses propres repos	Apache 2.0	Note les projets (branch protection, maintenance, signatures…).
Socket.dev	Détection de paquets malveillants	SCA	SaaS freemium	Analyse le **comportement** des paquets (typosquatting, scripts d'install), là où le SCA classique ne voit que les CVE connues.
Harbor	Registre d'images	Scan intégré (Trivy), signature, réplication	Apache 2.0	Registre on-prem CNCF qui centralise scan et politiques.

5. Images de conteneurs (CA)

Vulnérabilités de l'OS de base et des paquets embarqués dans l'image.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Trivy image	Scan d'images	SBOM, secrets, misconfig	Apache 2.0	Référence open source, rapide, OS + dépendances applicatives.
Grype	Scan d'images	Scan de SBOM	Apache 2.0	Alternative à Trivy, combiné à Syft.
Docker Scout	Scan d'images	Recommandations d'images de base	Freemium	Intégré à Docker Desktop/Hub, pratique côté dev.
Snyk Container	Scan d'images	Suggestion d'image de base moins vulnérable	SaaS	Propose des upgrades d'image de base concrets.
Hadolint	Lint Dockerfile	—	GPL	Bonnes pratiques Dockerfile, en amont du scan d'image.
Images distroless / Chainguard / Docker Hardened Images	Images minimales	—	Variable	Moins de paquets = moins de CVE : réduit le bruit à la source.

6. IaC et policy as code

Mauvaises configurations dans l'infrastructure décrite en code, et règles imposées automatiquement.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Checkov	Scan IaC	Secrets, SCA basique, Dockerfile ; **Ansible** (bonne couverture)	Apache 2.0	La plus large couverture IaC : Terraform, K8s, Helm, CloudFormation, Bicep, Ansible…
Trivy config	Scan IaC	Terraform, K8s, Helm, Dockerfile ; **Ansible partiel**	Apache 2.0	A absorbé tfsec. Pratique pour n'avoir qu'un outil, moins complet que Checkov sur Ansible.
ansible-lint	Lint Ansible	Quelques règles de sécurité	MIT	Complément indispensable pour Ansible : bonnes pratiques et erreurs courantes.
KICS	Scan IaC	Ansible, Terraform, K8s…	Apache 2.0	Alternative open source (Checkmarx), bonne couverture Ansible.
Terrascan	Scan IaC	—	Apache 2.0	Projet archivé : à éviter pour un nouveau projet.
OPA / Conftest	Policy as code	Tout fichier structuré	Apache 2.0	Règles maison en Rego, testées en CI.
Kyverno	Policies Kubernetes	Vérification de signatures Cosign à l'admission	Apache 2.0	Policies en YAML, plus accessible qu'OPA Gatekeeper pour du K8s.

7. DAST (application en fonctionnement)

Attaque de l'application déployée, comme un attaquant externe.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
OWASP ZAP	DAST	Tests d'API (OpenAPI)	Apache 2.0	Open source, baseline scan facile en CI.
Nuclei	Scan à base de templates	Misconfig, CVE d'infra exposée	MIT	Très rapide, énorme bibliothèque communautaire.
Burp Suite	DAST / pentest	—	Propriétaire	Référence du pentest manuel ; édition DAST pour l'automatisation.
StackHawk	DAST orienté CI/API	—	SaaS	Basé sur ZAP, pensé pour les devs et les API.

8. Sécurité runtime et gestion des secrets

Ce qui se passe une fois en production.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Falco	Détection runtime	—	Apache 2.0	Projet CNCF : shell dans un pod, lecture de /etc/shadow, etc.
Tetragon	Runtime eBPF	Blocage (enforcement)	Apache 2.0	Observabilité et blocage au niveau noyau (Cilium).
HashiCorp Vault / OpenBao	Gestion de secrets	PKI, secrets dynamiques	BSL / MPL 2.0	OpenBao : fork open source après le passage de Vault sous BSL.
External Secrets Operator	Secrets dans K8s	—	Apache 2.0	Synchronise Vault, AWS SM, etc. vers des secrets K8s.

9. Observabilité, DORA et SIEM

Supervision infra, applicative, des performances de livraison et de la sécurité.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
Prometheus + Grafana	Métriques infra	Alerting	Apache 2.0 / AGPL	Standard de fait, surtout en Kubernetes.
PLG (Loki + Grafana)	Logs applicatifs	—	AGPL	Moins cher qu'ELK (index sur labels seulement). **Promtail est déprécié : passer à Grafana Alloy.**
OpenTelemetry	Instrumentation	Traces, métriques, logs	Apache 2.0	Standard pour éviter le lock-in fournisseur.
Tempo / Jaeger	Traces distribuées	—	AGPL / Apache 2.0	Complète PLG → stack LGTM.
ELK / OpenSearch	Logs	SIEM (Elastic Security / OpenSearch Security Analytics)	Elastic / Apache 2.0	Recherche plein texte plus puissante que Loki, plus gourmand.
Apache DevLake	Métriques DORA	—	Apache 2.0	Calcule les 4 métriques DORA depuis Git, CI et tickets. **PLG ne le fait pas nativement.**
Wazuh	SIEM / XDR	Conformité, FIM, scan de vulnérabilités hôtes	GPL	Le SIEM open source le plus courant.
Microsoft Sentinel / Splunk / Elastic Security	SIEM	SOAR	Propriétaire	Sentinel sur Azure, Splunk en grand compte, Elastic si ELK déjà en place.

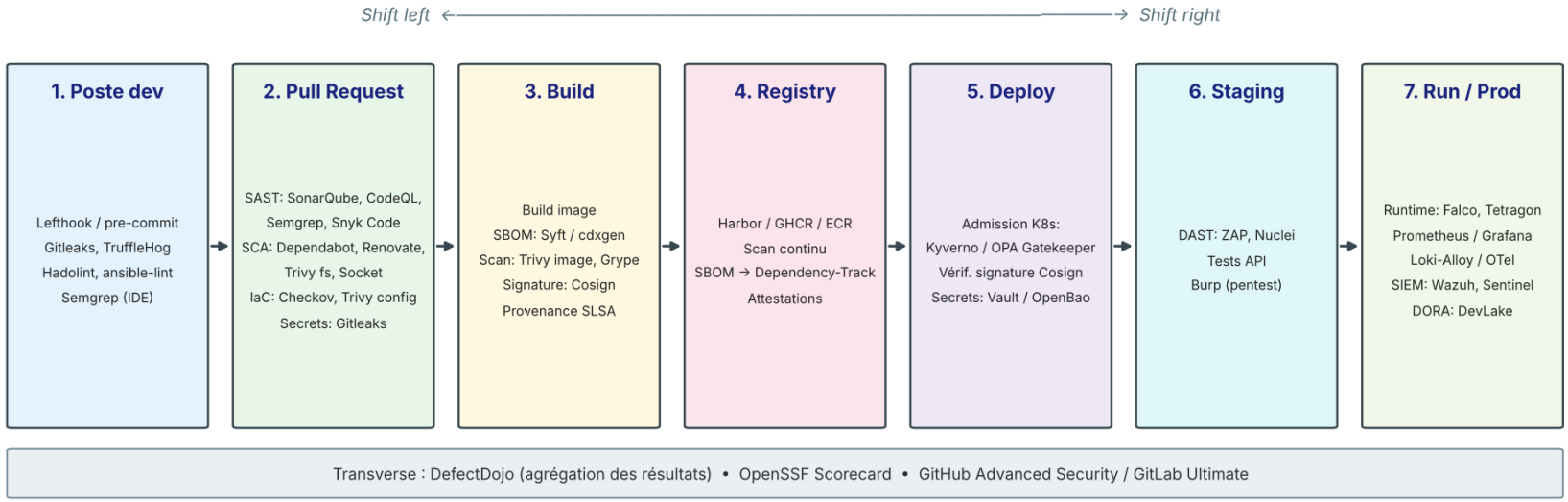
10. Centralisation des résultats (ASPM)

Indispensable dès qu'on dépasse trois scanners, pour ne pas se noyer dans les rapports.

Outil	Catégorie principale	Autres capacités (moins réputé / partiel)	Licence	Pourquoi / vs les autres
DefectDojo	Agrégation de vulnérabilités	Gestion des faux positifs, SLA	BSD	Importe 200+ formats (Trivy, ZAP, Semgrep…), déduplique, suit le cycle de vie.
GitHub Advanced Security / GitLab Ultimate	Plateforme intégrée	SAST, SCA, secrets, container	Propriétaire	Tout dans la forge, au prix d'un lock-in.

11. Placement dans un pipeline CI/CD

Principe : les contrôles rapides le plus à gauche possible (shift left), les contrôles lents ou nécessitant l'application déployée à droite (shift right).



Étape	Outils	Comportement conseillé
1. Poste dev	Lefthook (ou pre-commit) + Gitleaks, Hadolint, ansible-lint ; plugin IDE Semgrep/Snyk/SonarLint	Rapide (< 10 s). Informer le dev au plus tôt.
2. Pull Request	SAST : SonarQube, CodeQL, Semgrep · SCA : Dependabot/Renovate, Trivy fs, Socket · IaC : Checkov, Trivy config · Secrets : Gitleaks/TruffleHog	Bloquer sur les vulnérabilités critiques/hautes nouvelles (quality gate). Ne scanner que le diff si possible.
3. Build	Build de l'image · SBOM avec Syft ou Trivy · Scan Trivy image/Grype · Signature Cosign · Attestation de provenance SLSA	L'image n'est poussée que si le scan passe ; SBOM et provenance attachés à l'image.
4. Registry	Harbor / GHCR / ECR · SBOM envoyé à Dependency-Track	Rescan continu : une CVE publiée demain doit lever une alerte sur les images déjà livrées.
5. Déploiement	Kyverno / OPA Gatekeeper · Vérification de signature Cosign · Vault/OpenBao + External Secrets	Refuser à l'admission toute image non signée ou non conforme.
6. Staging	ZAP (baseline puis full scan), Nuclei, tests d'API ; pentest Burp ponctuel	DAST complet en nightly plutôt qu'à chaque PR (trop long).
7. Run / Prod	Falco/Tetragon · Prometheus/Grafana · Loki + Alloy / OpenTelemetry · Wazuh ou Sentinel · DevLake (DORA)	Alertes Falco et événements de sécurité remontés au SIEM.
Transverse	DefectDojo · OpenSSF Scorecard	Un seul endroit pour trier, prioriser et suivre les vulnérabilités.